Submission detail	Information
Student name	Chidinma Ruth Igboanu
Student ID	**2025/GRC/10337**
Official email	grc2510337@students.icdfa.edu.ng
Programme	Governance, Compliance, and Risk Training Program
Assessment	Individual assignment — all six tasks
Word count	Approximately 4,000 words excluding tables and references; confirm after final edits
Scenario	Northbridge Skills Institute — suspected ransomware incident

Executive Summary

At 08:45 WAT on Day 0, Northbridge Skills Institute should declare a Critical cybersecurity incident following the attack. It was discovered that ransomware has also been confirmed on the finance computer (FIN-PC07) and the shared file server (FS01). Students also can't reach learning materials or submit assessments on LMS01.

Two other things are worrisome: about 1.2 GB of data left the network, and the svc_backup account is behaving unusually. This is enough to act urgently. It is not enough to say who the attacker is, what was in the transfer, or whether all student records were stolen.

Our priorities are to:

- stop the encryption and its spread
- protect the backups
- secure accounts that may be compromised
- keep the evidence
- keep communication trusted
- make a safe decision about the 11:00 exam

My recommendation to Northbridge is; do not restore the portal from an untested backup. We should also not reconnect infected systems to meet the exam time. Instead, academic staff should seek approval to postpone the exam or use an alternative assessment method.

The plan highlighted below follows the four stages from the course slides: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity. I also used NIST SP 800-61 Rev. 3 as a current reference for risk management. The plan is built for a small IT team, and the roles and contacts are fictional.

Incident assessment and governance

Task 1 - Incident classification and initial assessment

Timeline (WAT)	Confirmed Observations	Working Hypothesis	Unresolved Questions
Day -1, 16: 40	E01: Finance officer opens unexpected payroll on FIN-PC07.	Assumptions that the attachment may have delivered an initial payload or credential theft	Was a file executed, macro enabled or credential entered.
Day 0, 01:15	E02: Finance officer account signed in from unknown IP and new device; we don't know if MFA was used or if the user did	The account may be hacked or a login token stolen. It could also be that the user is in transit or using a new device or on a VPN	Did MFA pass? Were any sessions, mailbox rules or app permissions changed?
Day 0, 01:35	svc_backup logged in as admin to FS01 and BAK01 at an unusual time.	An attacker may be using this account to reach files and backups.	Was it planned automation or maintenance, or someone using it without permission?
Day 0, 01:50	FIN-PC07 uploaded 1.2 GB over HTTPS to cloud storage we don't recognise. We don't know what was sent.	Data may have been stolen. It could also be a normal sync or an approved transfer.	Where did it go, what files were sent, which program sent them, and which user or session was behind it?
Day 0, 02:00	The backup console says the FS01 and LMS01 backups worked. We don't know if they can be restored or are clean.	The backups may be fine. They may also be incomplete, damaged or tampered with.	Can we restore them offline and scan them? What did they cover?
Day 0, 08:30	Many files changed on FIN-PC07. FS01 has locked files and a ransom note. We don't know the malware type.	Ransomware is encrypting files now or already has, and it may still be spreading.	Which machines, accounts, shares and programs are involved?
Day 0, 08:40	The LMS01 login page loads, but learners can't open materials or submit assessments. We don't know how far this goes.	The portal probably depends on FS01, which would explain the outage. LMS01 itself may also be affected.	Is the damage only to shared content, or also to the LMS program, database or logins?
Day 0, 08:45	The contact list on FS01 can't be opened. Phones work. We aren't sure we can trust company email.	We can't easily reach the right people, and messages may not be safe.	Can we get contacts from paper or offline records and confirm them by phone?

- **Incident type, Severity and Rationale**

Incident type: suspected ransomware with confirmed ransomware indicators, potential privileged-account compromise, service disruption, and possible data exfiltration. The malware family and initial access method remain unconfirmed.

1.2 Incident type, severity and rationale

Incident type: suspected ransomware with confirmed ransomware indicators, potential privileged-account compromise, service disruption, and possible data exfiltration. The malware family and initial access method remain unconfirmed.

Severity	Proposed criteria
Critical	Actively disrupt critical or core business operations, ransomware on company's infrastructure, compromise on backups, high probability of a personal data being exposed
High	Compromised systems and sensitive data which can be managed, requires rapid response and management oversight
Medium	Contained incident affecting a limited asset or user, no evidence of lateral movement, and low business impact.
Low	Low-confidence or low-impact event with no confirmed compromise; routine investigation and tracking are sufficient.

1.3 **1.3 CIA impact and affected assets**

Asset/ Data	Status	Confidentiality	Integrity	Availability	Priority
FIN-PC07	Confirmed affected (E06); E01/E04 linked	Potential exposure of finance data and credentials; transfer contents unknown.	Mass file changes indicate possible alteration/encryption.	Workstation functionality impaired.	Isolate; preserve volatile evidence; investigate transfer and entry point.
FS01	Confirmed affected (E06)	Shared files may have been accessed; scope unknown.	Locked files and ransom note indicate data is unavailable and may have been altered.	Shared folders unavailable; LMS materials depend on it.	Isolate; protect other shares and backup paths; capture evidence.
LMS01	Service impact confirmed (E07); technical scope unknown	Learner data exposure not established.	Underlying materials and assessment records may be affected through FS01 dependency.	Learners cannot access materials or submit assessments.	Keep offline from compromised dependencies; plan safe alternative assessment.

BAK01	Potentially affected (E03); backup compromise unconfirmed	Backup data may contain personal/finance records.	Backup integrity and administrator activity require validation.	Recovery capability at risk; network backups not immutable.	Restrict access and isolate from production; preserve logs; test copies in quarantine.
Microsoft 365 / finance identity	Suspicious sign-in (E02)	Mailbox, files or tokens may be exposed.	Mailbox rules, OAuth grants or identity settings may have been changed.	Account/session availability and trust uncertain.	Revoke sessions, reset credentials from clean device, check audit logs.
Learner, admission, assessment and finance records	Potentially affected; no confirmed theft	Risk depends on what was accessed or transferred.	Records may be encrypted or altered; validate from known-good sources.	Access impaired for portal-linked content.	Legal/privacy risk assessment; preserve records; communicate facts carefully.

1.4 **Alternative explanations and Priority questions**

Ambiguous event alternatives:

- E02 may represent compromised credentials or token theft; alternatively, the finance officer may have used a new device, VPN, or legitimate remote connection—Correlate MFA records, device registration, sign-in risk, IP reputation and user interview before deciding.
- E03 may be attacker use of svc_backup for lateral movement; alternatively, a scheduled job or authorised administrator may have run outside its usual schedule. Verify change tickets, service-task history, source host, command line and administrator confirmation.
- E04 may be data exfiltration; alternatively, an approved or unauthorised but non-malicious cloud sync could explain the upload. Proxy, DNS, firewall, endpoint process, cloud destination and file-access logs are needed to identify content and motive.

Priority question	Collection / validation check	Finding that changes scope or severity
Was personal or finance data accessed or exfiltrated?	Preserve proxy/DNS/firewall logs, EDR telemetry, file-access logs, cloud destination metadata and relevant M365 audit records; compare file access with transfer time.	Evidence of learner/finance data transfer increases privacy impact and may trigger formal notification. Evidence of no data access narrows confidentiality risk but must be supported.

How did the attacker enter and move laterally?	Collect original email and attachment, endpoint image/EDR telemetry, Windows event logs, authentication logs, scheduled tasks, remote logons and network connections.	A common foothold on other systems, domain compromise or persistence beyond two hosts broadens the incident and requires wider isolation and credential resets.
Is svc_backup compromised and are backups clean?	Review service-account logons, process/command execution, backup-console audit logs, repository access, retention/deletion events; test a copy in isolated recovery environment.	Evidence of backup deletion/encryption or attacker control of backup admin plane increases severity and lengthens recovery; verified clean offline backup improves recovery confidence.
What is the actual LMS impact?	Inspect LMS01 application/database logs, dependencies, file integrity, service health and a controlled test copy.	Evidence of direct LMS compromise or assessment-record alteration broadens rebuild and data-integrity work; confirmed dependency-only outage may permit faster staged recovery.

Our first priorities, in this order:

1. Stop the encryption and stop it spreading to other machines.
2. Cut off FS01, FIN-PC07 and the network paths linked to them, and keep BAK01 (the backup server) safe.
3. Lock down accounts and admin sessions that may be compromised.
4. Keep the evidence.
5. Decide with the academic owner what happens to the exam.
6. Work out the privacy risk and prepare accurate messages for staff and learners.

Task 2 — Incident response plan and team duties (20 marks)

2.1 Policy and plan outline

Element	Northbridge rule
Mission	Protect learners, staff, information and essential education services by detecting, containing, investigating and recovering from incidents with documented decisions.
Objectives	Limit harm; preserve evidence; maintain essential business/academic continuity; meet applicable obligations; restore only trusted services; learn and improve.
Scope	All institute endpoints, servers, networks, Microsoft 365, identities, cloud services, backups, learner/finance data, suppliers and staff.
Declaration	Incident Manager declares an incident when credible evidence indicates actual or imminent compromise. Critical classification is approved immediately by the Incident Commander; response begins before perfect certainty.

Activation/escalation	Critical: immediate full CSIRT activation and executive notification; High: rapid response and management notification; Medium/Low: assigned incident ticket and scheduled review. Reassess severity as evidence changes.
Authority	Incident Commander may order emergency isolation of a host, account or network segment to prevent material harm. If delay risks spread, isolation may occur before executive approval; record rationale, time, approver notified and business impact.
Documentation	Maintain one incident ID, timeline, evidence register, custody log, decision log, impact assessment, communications log, approvals, recovery tests and closure report.
Communications	Use staff phones and a verified out-of-band channel until corporate email and identities are trusted. Only the Communications Lead issues external statements after approval.
Review	Review the plan at least annually and after a major incident, significant system change, exercise failure or change in legal requirements.
Business continuity	The Business Continuity Lead prioritises teaching, exams, learner support and finance operations. Use approved alternate channels/processes; do not bypass security gates to restore a deadline-driven service.

2.2 CSIRT structure

Role	Primary duties / authority	Named fictional contact
Incident Commander / Incident Manager	Owns severity, objectives, resource priorities, decision log and escalation; chairs briefings; accountable for incident coordination.	Amina Okafor, +234 800 555 0101
Security Analyst / Technical Lead	Correlates EDR, identity, network and server logs; tracks indicators; coordinates threat hunting and scope assessment.	Tunde Bello, +234 800 555 0102
Forensics and Evidence Lead	Plans collection, imaging, hashes, custody and secure storage; advises on evidence-preserving containment.	External retainer initially; +234 800 555 0103
IT Operations Lead	Isolates/rebuilds systems, manages network controls, identity resets, backup protection and recovery environment.	Chika Eze, +234 800 555 0104
Business Continuity / Academic Owner	Decides examination and learner-service alternatives; sets operational acceptance requirements and authorises business service return.	Dr. Sola Adeyemi, +234 800 555 0105
Legal / Privacy Adviser (DPO)	Assesses data-protection obligations, legal privilege, regulator/data-subject notification and evidence preservation.	Nneka Obi, +234 800 555 0106
Communications Lead	Coordinates staff, learner, media and stakeholder messaging; maintains approved facts and update cadence.	Musa Danjuma, +234 800 555 0107

Executive Sponsor	Approves extraordinary spend, risk acceptance and material business decisions; resolves conflicts between security and service pressure.	Managing Director, +234 800 555 0108

Northbridge should also activate a pre-approved external incident response/forensic retainer, because the in-house team consists of 3 IT staff and one security analyst. We may also contact its cyber insurer, if applicable, request specialist support from relevant providers, and obtain external legal/privacy advice. The internal Incident Commander retains decision accountability; outsourced specialists advise and execute agreed tasks.

2.3 RACI matrix

R = Responsible (performs the work); A = Accountable (one role ultimately answerable); C = Consulted; I = Informed. Exactly one A is assigned to each activity.

Activity	Incident Cmdr	Security	Forensics	IT Ops	Business Owner	Legal/DPO	Comms
Detection / declaration	A	R	C	R	I	I	I
Analysis / scope	A	R	R	C	C	C	I
Containment	A	R	C	R	C	C	I
Evidence handling / custody	A	C	R	C	I	C	I
Stakeholder communications	A	C	I	I	C	C	R
Reporting-obligation assessment	A	C	C	I	I	R	C
Restoration approval	C	R	C	R	A	C	I
Closure / lessons learned	A	R	C	C	C	C	R

2.4 Readiness improvement checklist

Improvement	Owner	Resources	Readiness evidence / test
Offline, encrypted and immutable backups; separate backup admin identity	IT Operations Lead	Backup storage, access separation, budget and runbook	Quarterly isolated restoration; record recovery time, data integrity and restore success; alert on deletion/privilege changes.
Offline incident contact list and out-of-band communications	Incident Commander	Printed sealed copies, verified phone tree,	Quarterly call-tree test; all critical contacts acknowledge within 15 minutes.

		independent conferencing	
Complete EDR/server logging and central log retention	Security Analyst	Server EDR licences, SIEM/log storage, alert tuning	Coverage report for all critical assets; simulated alert reaches on-call analyst within 15 minutes.
Forensics kit and evidence-handling procedure	Forensics Lead	Write blockers, clean media, imaging tools, encrypted evidence store, forms	Annual evidence collection exercise; sample hash verified by a second person and custody form complete.
Least privilege and service-account hardening	IT Operations Lead	PAM or vault, managed service identities, MFA, network segmentation	Quarterly privilege review; svc_backup cannot administer production and backup using one reusable credential.
Tabletop and role-specific training	Incident Commander / HR	Facilitator, scenario pack, staff time	Two exercises per year; score decisions against measurable objectives and close corrective actions.

Task 3 — Response playbook and evidence preservation

3.1 First 60 minutes and first 24 hours

The clock begins at 08:45 WAT on Day 0. Times below are proposed response targets, not claims that actions have already occurred. If evidence preservation would delay stopping active encryption or spread, isolate first and document the trade-off.

Time / stage	Action	Owner	Approval	Evidence to retain	Completion check
08:45 – 08:50	Declare Critical incident; assign incident ID; activate CSIRT; start timeline and decision log.	Incident Commander	Incident Commander; notify Executive Sponsor	Initial reports, E06–E08, timestamps	Roles acknowledged; next briefing scheduled.
08:45 – 08:55	Move coordination to verified phone/out-of-band channel; warn staff not to use corporate email for incident coordination.	Comms Lead	Incident Commander	Call log, approved holding message	Core team reachable and channel tested.
08:50 – 09:00	Isolate FIN-PC07 from network and Wi-Fi; do not casually power it off if network isolation is possible.	IT Ops	Emergency authority: Incident Commander	EDR alert, network connections, memory capture plan	Host cannot communicate with peers/internet; action timestamped.

08:50 – 09:05	Isolate FS01 from affected network paths; restrict SMB/share access; preserve server logs and, if feasible, volatile evidence before shutdown.	IT Ops + Forensics	Incident Commander	Server logs, snapshot/image plan, ransom note, sample file metadata	Encryption/lateral movement stopped or residual risk documented.
08:50 – 09:05	Protect BAK01: block production access except approved response route; disable or restrict svc_backup after preserving relevant authentication/session evidence where safe.	IT Ops + Security	Incident Commander	Backup audit logs, identity logs, access-control changes	Backup console no longer reachable from compromised hosts.
09:00 – 09:10	Revoke finance user sessions; reset password from a clean device; verify MFA, mailbox rules, OAuth apps and new device registrations.	Security + IT Ops	Incident Commander	M365 audit exports, sign-in records, before/after settings	Suspicious sessions revoked and identity hardening verified.
09:00 – 09:15	Block confirmed malicious indicators only after validation; review DNS/proxy/firewall for cloud destination and other affected hosts.	Security Analyst	Incident Commander	Network logs, indicator rationale, rule-change log	Block tested; no broad block that disrupts unrelated services without approval.
09:05 – 09:20	Preserve original payroll email/attachment, endpoint telemetry, Windows logs, ransom note and relevant timestamps; use write-protected evidence media where possible.	Forensics Lead	Incident Commander	Original email, image/log exports, hashes after collection	Collection logged; evidence sealed and custody recorded.
09:10 – 09:25	Scope threat: search for svc_backup use, new admins, remote logons, scheduled tasks, EDR gaps, lateral movement and suspicious M365 activity.	Security + IT Ops	Incident Commander	Queries, exported logs, affected-asset list	Initial scope map lists confirmed, suspected and cleared assets.

09:15 – 09:30	Notify Executive Sponsor, academic owner, legal/privacy adviser and external IR provider; confirm examination decision pathway.	Incident Commander	Executive Sponsor informed	Briefing version, approvals, call timestamps	Owners understand facts, uncertainties and decisions required.
09:20 – 09:40	Assess E04 upload; correlate process, file access, destination, DNS, proxy and endpoint data. Preserve logs before expiry.	Security + Forensics	Incident Commander	Proxy/DNS/EDR/file access logs	Data-transfer assessment states known, unknown and confidence.
09:30 – 09:45	Decide 11:00 examination status. Prepare postponement/alternative plan; do not reconnect LMS/FS01 or restore unverified backup.	Academic Owner	Academic Owner accountable; executive consulted	Decision and learner impact, approved message	Decision issued to learners via trusted channel.
09:45 – 10:15	Begin controlled backup validation: copy candidate backup to isolated recovery environment; test readability, malware indicators, integrity and restore dependencies.	IT Ops + Forensics	Incident Commander approves test; business owner not yet approves production	Backup job logs, snapshot metadata, test results	No production restore until criteria pass.
10:15 – 12:00	Expand scope across endpoints, servers, M365, backup plane, network appliances and supplier access; close EDR blind spots with logs and manual checks.	Security Analyst	Incident Commander	Search queries, log sources, host inventory	Scope updated; unknown assets and coverage gaps explicit.
12:00 – 16:00	Identify entry point, persistence, privilege escalation, lateral movement and possible exfiltration; preserve malware samples safely.	Security + Forensics	Incident Commander	Images, malware indicators, tasks/services, authentication events	Root-cause hypothesis documented with confidence and alternatives.
16:00 – 20:00	Plan eradication: rebuild from known-good images, patch	IT Ops + Security	Incident Commander;	Build baselines, patch records,	Approved rebuild plan covers affected

	exploited weaknesses, remove persistence, rotate exposed secrets and redesign access paths.		executive for material spend	credential rotation log	and potentially affected systems.
20:00 –Day 1 08:45	Restore priority services only in clean segmented environment; test data integrity, authentication, dependencies, logging and backup safety; monitor for recurrence.	IT Ops	Business Owner approves service return after technical/security sign-off	Restore logs, test scripts/results, monitoring alerts	Acceptance criteria below passed; residual risks accepted in writing.

3.2 Difficult decisions

Containment versus evidence: the preferred action is network isolation, which often stops communication while protecting local volatile evidence. Forensics should capture memory and active connections in which feasible without delaying containment. If active encryption is spreading and imaging would cause a material delay, isolate immediately; if isolation is impossible, power down only as a last resort because volatile evidence may be lost. Record the exact action, time, reason, expected evidence loss, operational impact and approver.

Examination access versus backup uncertainty: service restoration is not approved solely because a job reported success (E05). The most recent disconnected backup is three days old, network backups are not immutable, and restoration has not been tested in 90 days. A failed test or evidence of compromise means the backup is not acceptable. The academic owner should postpone or use a separately approved, unaffected alternative process. Do not reconnect LMS01 to FS01 until technical and business acceptance criteria are met.

3.3 Evidence register and custody

All items below are proposed collections. Collection date/time is to be recorded by the collector at acquisition in WAT; no hashes or completed acquisitions are asserted in this plan.

ID / source	Proposed collection method	Collector / time	Integrity and secure storage	Custody / access
ER01 — FIN-PC07; E01, E04, E06	Preserve original email and attachment; collect EDR telemetry; capture memory and forensic disk image where feasible; export proxy/DNS logs.	Forensics Lead with Security Analyst; planned, Day 0 WAT time to be recorded at collection.	Calculate SHA-256 hashes at acquisition and verify after transfer; store encrypted, access-controlled evidence copy; retain working copy separately.	Collector signs acquisition form; every transfer records sender, recipient, time, purpose and seal/hash check. Forensics, Legal/DPO only by approved need.

ER02 — FS01; E03, E06	Export Windows Security/System logs, share-access logs, ransom note and file metadata; snapshot/image server before remediation where feasible.	Forensics Lead + IT Ops; planned, Day 0 WAT time to be recorded.	Hash each exported file/image; record tool/version, host, time source and any collection limitation; encrypted evidence repository.	Two-person verification for evidence transfer; no ordinary admin access to master evidence.
ER03 — BAK01 / backup console; E03, E05	Export backup audit logs, job reports, repository access, retention/deletion events and snapshot metadata; create isolated test copy.	IT Ops + Forensics; planned, Day 0 WAT time to be recorded.	Hash exports and test-copy manifest; original backup preserved read-only where possible; test in isolated network.	Backup custodian logs each access; separate backup credentials; test results stored with incident ID.
ER04 — Microsoft 365 identity; E02	Export sign-in, MFA, audit, mailbox-rule, OAuth consent, session and device-registration records using authorised admin workflow.	Security Analyst; planned, Day 0 WAT time to be recorded.	Record export time range, tenant, query and export hash; encrypted storage; preserve native format.	Restricted to Security, Forensics and Legal/DPO; export and review logged.
ER05 — LMS01; E07	Preserve application, web, database and authentication logs; record dependency failures; capture image/snapshot if safe.	IT Ops + Forensics; planned, Day 0 WAT time to be recorded.	Hash log bundles and images; retain source copies; document clock offsets and missing logs.	Controlled evidence store; only approved responders and counsel access.

Evidence access is least-privilege, logged and limited to named responders and advisers with a defined need. Keep master evidence read-only; use working copies for analysis. Record system clock offsets, tool versions, collection errors and every custody transfer. Do not email evidence or place it in the potentially compromised shared disk.

3.4 Eradication and recovery acceptance

- Remove persistence by examining scheduled tasks, services, startup items, scripts, registry run keys, remote management tools, new accounts, OAuth grants, mailbox rules and other persistence mechanisms. Rebuild affected hosts from known-good images where confidence in cleaning is insufficient.
- Address likely entry through the unexpected payroll attachment: inspect the original report, attachment execution, email controls and user activity; block related indicators; patch exposed software; improve attachment sandboxing and user reporting.
- Treat finance identity and svc_backup as potentially compromised until evidence supports otherwise. Revoke sessions/tokens, rotate credentials and secrets from clean

devices, enforce MFA, separate service identities, remove unnecessary admin rights and review all privileged access.

- Restore in order based on dependency and business impact: (1) clean identity, network management and logging foundations; (2) backup control plane in isolation; (3) required file services and verified data; (4) LMS and assessment dependencies; (5) finance workstation and remaining services—Reorder only with documented risk rationale.
- Proposed recovery targets (planning assumptions, not existing commitments): RTO for essential learner communications: 4 hours; core learning/assessment service: 24 hours if safe; finance operations: 72 hours. Proposed RPO: learner assessment records no more than 4 hours of loss; finance records no more than 24 hours; validate feasibility with business owners.
- Select backups by provenance, time, access history, immutability/offline status and known-good scan results—not simply the latest successful job. Restore a copy into a quarantined, segmented environment; scan with updated tools; compare hashes/record counts and application-level integrity; look for encryption, suspicious accounts and persistence; run user acceptance tests.
- Monitor restored systems with enhanced EDR/logging and review authentication, file changes, outbound traffic and backup activity continuously for at least 72 hours, then daily for 14 days. Any recurrence returns the service to containment.
- Service return requires Security and IT technical sign-off, Forensics confirmation that evidence is preserved, Legal/Privacy review of unresolved obligations, and written approval from the business owner. The Incident Commander records residual risk and approval.

Recovery acceptance criteria: clean build or verified restore source; known entry point mitigated; compromised credentials rotated; no unexplained privileged logons; critical EDR/logging coverage active; information consistency checks pass; backup access separated from production; key business workflows pass; monitoring and rollback plan active; and business owner signs acceptance.

Task 4 — Communication and escalation (10 marks)

4.1 Communication matrix

Stakeholder	Trigger	Message owner	Channel / alternative	Approver	Frequency
Executive Sponsor / Board	Critical declaration; material scope, cost or service change	Incident Commander	Verified phone / out-of-band bridge	Incident Commander; executive sponsor for decisions	Every 30 minutes for first 4 hours, then every 2 hours or on

					material change
IT and security responders	Immediate activation and each containment/recovery change	Security Analyst	Dedicated phone bridge; no untrusted email	Incident Commander	Continuous operational updates; 15-minute huddles initially
Learners	Exam status, service availability, actionable safety guidance	Communications Lead + Academic Owner	Verified SMS, LMS banner only if trusted, public website/social account after validation; phone support	Academic Owner and Legal/DPO; Incident Commander approves facts	At decision point, then every 2 hours while exam/service status changes
Staff and faculty	Containment instructions, phishing warning, operational workaround	Communications Lead	Phone tree, approved SMS, in-person supervisor cascade	Incident Commander	Initial notice and every 2 hours or when instructions change
Legal / Privacy Adviser / DPO	Possible personal-data exposure or reportable breach	Incident Commander	Direct phone and secure approved channel	Legal/DPO leads legal assessment	Immediate; then at each material evidence update
Relevant service providers / Microsoft 365 / ISP / external IR	Need to preserve logs, block destination, secure tenant or obtain expertise	IT Operations Lead	Verified support portal/phone from known contact record	Incident Commander	Immediate engagement; hourly during active containment
Regulator / law enforcement	Legal threshold met or counsel recommends reporting	Legal/DPO	Official verified reporting channel	Authorised executive with Legal/DPO	Within applicable statutory timeframe; record submission and receipt
Media / public	Journalist inquiry or misinformation materially affecting learners	Communications Lead	Approved public statement and direct response	Executive Sponsor and Legal/DPO	Holding statement promptly; update when material facts change

4.2 Executive briefing (150–200 words)

At 08:45 WAT, Northbridge Skills Institute has declared a Critical cybersecurity incident. Current evidence confirms ransomware indicators on finance workstation FIN-PC07 and shared file server FS01, including mass file changes, .locked files and a ransom note (E06). Learners cannot access materials or submit assessments through LMS01, which depends on FS01 (E07). A finance account signed in from an unfamiliar IP/device, svc_backup made unusual administrator logons to FS01 and BAK01, and FIN-PC07 uploaded 1.2 GB to unfamiliar cloud storage (E02–E04). These events raise concern about identity compromise, backup risk and possible data exfiltration, but we do not yet know what was transferred or whether personal data was stolen. Backup job success does not prove recoverability or cleanliness (E05).

We are isolating affected systems, restricting backup access, securing identities, preserving logs and engaging external forensic support. I recommend postponing the 11:00 examination or moving it to an approved alternative rather than reconnecting unverified systems. Emergency external support and learner communications require approval. Legal/privacy advisers are assessing notification obligations against confirmed facts. Corporate email remains untrusted pending checks; staff phones are the fallback. The next executive update will be at 09:15 WAT, or earlier if scope or recovery risk changes.

4.3 Learner notice (100–150 words)

Northbridge Skills Institute is investigating a cybersecurity incident which has temporarily affected access to learning materials and assessment submission. We are taking protective steps and checking the safety and soundness of affected systems. At this time, we have not confirmed that learner personal information has been accessed or stolen. We are reviewing the online examination scheduled for 11:00; please do not rely on unofficial social media posts for updates. We will confirm the examination arrangement through the Institute's verified SMS and authorized communication channels. Do not open unexpected attachments or share passwords, verification codes or personal information in response to messages claiming to be from the Institute. If you receive a questionable message, report it to your faculty contact by phone. Our next update is planned for 09:30 WAT, even if the investigation is still ongoing.

4.4 Legal/privacy assessment and escalation rules

Assuming Nigeria is the applicable jurisdiction, Legal/DPO should assess section 40 of the Nigeria Data Protection Act 2023. Section 40(2) requires a data controller to notify the Nigeria Data Protection Commission within 72 hours of becoming aware of a breach likely to result in risk to individuals' rights and freedoms; section 40(3) requires immediate communication to affected data subjects where the breach is likely to result in high risk. Counsel must verify applicability, the awareness trigger, risk threshold, controller/processor roles and current guidance. The Institute should not wait for perfect forensic certainty if it meets the legal threshold; it should document what is known, what is unknown, and the basis for any notification. A service-status notice is an operational communication, not a substitute for a formal breach notification. Cite: Nigeria Data Protection Act 2023, s.40 (NDPC official publication).

Escalate immediately if ransomware spreads beyond known assets, the backup control plane is compromised, privileged identity abuse is confirmed, a second exfiltration path is found, or

safe recovery is not achievable within the agreed business window. Communications must distinguish confirmed facts, working hypotheses and unconfirmed claims.

Task 5 — Tabletop exercise and improvement plan (15 marks)

5.1 Exercise design

Title: Northbridge ransomware response tabletop. Duration: 60 minutes. Format: facilitated discussion; no production systems are changed. This is a SIMULATION, not a record of real incident actions.

Objectives:

(1) test declaration, escalation and decision authority;

(2) decide safe containment while protecting evidence;

(3) test refusal to restore an unverified backup under deadline pressure;

(4) test response to possible data extortion and public misinformation;

(5) test clear communications and measurable recovery gates.

Participants: Incident Commander, Security Analyst, IT Operations Lead, Forensics Lead, Academic Owner, Legal/DPO, Communications Lead and Executive Sponsor. One person may play multiple roles because of to small-team constraints, but each decision must identify the role accountable.

Minute	Inject / activity	Discussion prompts and expected evidence
0–10	Initial situation: E01–E08; incident declaration	What is confirmed? Severity? Who can isolate? What is the first message? Evidence: incident timeline, initial decision log.
10–20	Inject 1: Management demands portal reopening before 11:00 despite unverified backup.	Does deadline override safety? Decide postponement/alternative assessment; specify technical gates for reopening.
20–30	Inject 2: Attacker claims all 1,800 learner records are held and threatens publication in 12 hours; screenshot authenticity unknown.	Preserve threat message; avoid validating attacker claim; investigate E04; engage Legal/DPO; prepare factual holding statement.
30–35	Inject 3: Scope review finds a suspicious privileged logon to another server.	Expand scope, isolate or restrict affected segment, review service-account reuse and identify additional log sources.
35–45	Inject 4: Test restoration of latest network backup fails with unreadable snapshot error.	Reject that restore point; protect backup plane; test offline disconnected backup or clean build; revise RTO and communicate uncertainty.
45–55	Inject 5: Social post says exam is cancelled; journalist asks if learner data was exposed.	Correct misinformation using verified channel; say exposure is unconfirmed; no speculation; one approved spokesperson.
55–60	Hotwash and scorecard	Score success criteria, capture gaps, assign owners/deadlines, agree review date.

5.2 Success criteria

- Declare a critical incident, and reach all core roles through out-of-band contact within 10 simulated minutes.
- Decision to isolate affected systems and restrict BAK01 documented with an owner, approval and evidence-preservation consideration within 15 simulated minutes.
- No participant authorises production restoration from an unverified backup; the decision and required acceptance tests are documented.
- Within 10 simulated minutes of the extortion claim, the team records it as unverified, preserves the message and refers risk assessment to Legal/DPO.
- The correct roles approve a learner/media holding statement that avoids unsupported claims about data theft.
- At least five corrective actions are assigned owners, target dates and measurable completion evidence before the exercise closes.

5.3 Simulated decision log

Inject	Decision	Decision owner	Rationale	Communication	Effect
Initial E06/E07	Classify as Critical and isolate FIN-PC07/FS01; restrict BAK01.	Incident Commander	Active ransomware indicators, service impact and possible backup-account misuse.	Phone bridge to responders and executive sponsor.	Limits spread; may interrupt services but protects recovery options.
Minute 10	Do not reopen LMS from unverified backup; postpone or use approved alternative examination arrangement.	Academic Owner; Incident Commander advises	E05 does not prove clean recoverability; LMS depends on FS01.	Verified learner SMS and faculty phone cascade.	Protects systems and assessment integrity; creates operational disruption.
Minute 20	Treat attacker's claim and screenshot as unverified; preserve them and investigate access/transfer evidence.	Security Analyst with Legal/DPO	A threat claim does not prove possession; E04 needs corroboration.	Executive and legal briefing; no public confirmation of theft.	Avoids amplifying misinformation while preserving extortion evidence.
Minute 35	Expand scope to the additional server and	Incident Commander	New suspicious	IT/security responders	Broader containment

	review shared credentials/privileged activity.		privileged activity means initial scope may be incomplete.	informed; update asset map.	may slow recovery but reduces reinfection risk.
Minute 45	Reject failed network snapshot; quarantine it for analysis and test the disconnected backup or rebuild clean.	IT Operations Lead; Incident Commander approves test	Unreadable snapshot and no recent restore test make it unsuitable for production.	Executive and academic owner told that timeline may slip.	Extends recovery estimate; prevents unsafe restoration.
Minute 50	Issue factual holding statement; direct journalist to spokesperson; correct exam misinformation.	Communications Lead; Executive Sponsor approves	Single source of truth reduces conflicting claims and avoids unverified statements.	Official website/SMS and direct media response.	Reduces confusion; no claim made that data was or was not stolen.

5.4 Simulated results and improvements

Simulation outcome: the team met the containment and communication objectives, but the failed snapshot exposed an unacceptable dependency on untested network backups. The exercise also showed that a deadline-driven business owner may pressure responders to bypass technical controls unless the plan clearly grants emergency isolation authority and defines a separate business-continuity decision path. The exercise does not establish actual technical capability; it identifies what must be tested.

Priority / improvement	Owner	Target	Measurable evidence of completion
P1 — Establish immutable/offline backups with separate admin credentials	IT Operations Lead	30 days	Successful isolated restore report for FS01 and LMS dependency data; backup admin cannot alter production and backup with one credential.
P1 — Quarterly restore test and recovery runbook	IT Operations Lead + Academic Owner	30 days for first test; quarterly thereafter	Recorded RTO/RPO results, integrity checks and signed acceptance.
P1 — Publish offline contact list and test out-of-band tree	Incident Commander	7 days	All CSIRT roles acknowledge a test call within 15 minutes; printed copies stored securely.
P1 — Extend EDR/log coverage to servers and backup environment	Security Analyst	45 days	Asset coverage report shows 100% of critical servers instrumented or documented compensating controls;

			simulated alert reaches analyst within 15 minutes.
P2 — Separate and harden svc_backup; review all privileged access	IT Operations Lead	14 days	Credential rotated, least privilege documented, MFA/PAM or equivalent applied where supported, quarterly review scheduled.
P2 — Implement evidence collection kit and custody forms	Forensics Lead	21 days	Exercise produces a verified hash, completed custody form and encrypted evidence archive with access log.
P2 — Create approved exam-continuity decision tree and learner templates	Academic Owner + Communications Lead	14 days	Signed playbook and one tested simulated learner notification through verified SMS/phone channel.
P2 — Conduct root-cause review and close action register	Incident Commander	Within 14 days of incident closure	Blameless review, timeline, root-cause analysis, named owners and closure evidence; executive sponsor signs off.

Post-incident review deadline: within 14 days after incident closure, matching the teaching deck's recommendation for a lessons-learned review within two weeks (slide 12). The Incident Commander owns the action register; the Executive Sponsor closes high-risk actions only after evidence is verified. Escalate overdue high-priority actions to executive management.

Task 6 — Case study analysis and critical reflection (300–400 words) (10 marks)

The teaching deck's illustrative healthcare ransomware case describes a mid-size organisation of 2,500 employees attacked through a phishing email carrying a malicious attachment. The malware persisted and moved laterally for 72 hours before encrypting systems. EDR alerts triggered on Day 4, after which the incident response team deployed, isolated network segments and quarantined affected systems. Offline backups were verified intact; the team restored critical systems within 72 hours, while full restoration took seven days. The organisation did not pay the ransom, reported no patient-data exfiltration, completed regulatory notifications on time and conducted a Day 14 review (ICDFA, GRC105, Week 20, slide 16). These are illustrative case claims, not independently verified forensic findings.

Three strengths stand out. First, EDR detection and immediate activation enabled coordinated containment once encryption began. Second, network segmentation limited ransomware spread and reduced the blast radius. Third, offline backups supported recovery without paying the ransom. The established response team and playbooks also appear to have helped coordination. Two limitations remain. Detection occurred only after 72 hours of stealthy movement, denoting a gap in earlier detection or threat hunting. The slide also states that no patient data was exfiltrated but does not show the forensic evidence, log coverage, retention period, or

validation method supporting that conclusion. The slide also notes that backup testing revealed gaps, but it does not detail the failed tests or how they were remediated.

Two lessons transfer directly to Northbridge. First, backups must be offline or immutable, separately administered and routinely restored in an isolated test environment. Northbridge's E05 backup job success is not evidence of recoverability, and E03 raises concern about svc_backup access to both FS01 and BAK01. Second, detection and segmentation must include servers and backup infrastructure, not only workstations; Northbridge's incomplete server EDR coverage increases risk and possible lateral movement.

Restoring critical services within 72 hours is not the same as full restoration in seven days. A staged recovery prioritises essential functions and minimum safe service, while full restoration includes remaining systems, data validation, backlog processing and hardened controls. Claiming no patient or learner data was stolen requires corroborated evidence: complete and trustworthy endpoint, identity, file-access, proxy, DNS, firewall and cloud logs; investigation of the 1.2 GB transfer; assessment of attacker access and persistence; and documented coverage limitations. Absence of an alert alone is insufficient.

After the tabletop, I would revise any plan that allows business pressure to override recovery validation. Northbridge should postpone the examination or use an approved alternative rather than restore from an unreadable or unverified backup.

References

1. ICDFA. (n.d.). Incident Response Planning. GRC105, Week 20 teaching deck, slides 1–18—supplied course material.
2. National Institute of Standards and Technology. (2025). SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. https://doi.org/10.6028/NIST.SP.800-61r3
3. Cybersecurity and Infrastructure Security Agency, National Security Agency, Federal Bureau of Investigation, and MS-ISAC. (2023). #StopRansomware Guide. https://www.cisa.gov/resources-tools/resources/stopransomware-guide
4. Federal Republic of Nigeria. (2023). Nigeria Data Protection Act, 2023, section 40. Nigeria Data Protection Commission. https://ndpc.gov.ng/wp-content/uploads/2024/03/Nigeria_Data_Protection_Act_2023.pdf